
Cuadernillo de Estudio — Clase 4

Gestión y Análisis de Riesgos en Sistemas de Información

Seguridad Aplicada a Sistemas de Información
Licenciatura en Sistemas de Información — Facultad de Informática y Diseño
Docente: Ing. Rodrigo Atilio Elgueta
Ciclo Académico Vigente

Índice

1. Objetivos de aprendizaje	2
2. Introducción a la Gestión de Riesgos	2
3. Conceptos Fundamentales	2
4. El Proceso de Análisis de Riesgos	4
4.1. Análisis Cualitativo	4
4.2. Análisis Cuantitativo	4
5. Diseño de Salvaguardas	5
6. Riesgo Residual	5
7. La Matriz de Riesgos	6
7.1. Estructura típica (enfoque cualitativo)	6
8. Glosario de conceptos clave	6
9. Autoevaluación	7
10. Respuestas de la Autoevaluación	7
11. Recordatorio: Actividad A03	9
12. Fuentes y bibliografía	10
12.1. Bibliografía obligatoria (según programa)	10
12.2. Bibliografía complementaria (según programa)	10
12.3. Portales y recursos web	10

1. Objetivos de aprendizaje

Al finalizar la lectura y el trabajo con este cuadernillo, el estudiante será capaz de:

- Comprender la **importancia y necesidad** de la gestión de riesgos en las organizaciones modernas.
- Diferenciar e interrelacionar los conceptos de **activo, amenaza, vulnerabilidad, impacto, probabilidad y riesgo**.
- Aplicar metodologías de **análisis de riesgos** cualitativo y cuantitativo.
- Diseñar **salvaguardas** apropiadas y calcular el **riesgo residual**.
- Elaborar una **matriz de riesgos** que sirva como insumo para la toma de decisiones y para la Actividad A03 (Trabajo Integrador).

Cómo usar este cuadernillo

Este material acompaña la Clase 4. Es la base metodológica para que puedas armar el **Análisis de Riesgos** de la empresa o caso que elegiste en la Actividad A00. Las respuestas de referencia de la autoevaluación se encuentran en la Sección 10.

2. Introducción a la Gestión de Riesgos

La seguridad informática **no se trata de eliminar todos los riesgos** (eso es técnica y económicamente imposible), sino de **gestionarlos** de manera eficiente. La gestión de riesgos es el proceso sistemático de identificar, analizar, evaluar y tratar los riesgos que pueden afectar a los activos de información de una organización.

Gestión de Riesgos

Conjunto de actividades coordinadas para dirigir y controlar una organización con respecto al riesgo. Incluye la identificación, el análisis, la evaluación y el tratamiento de los riesgos sobre los activos de información.

¿Por qué es necesaria?

Toda organización convive con la incertidumbre. Un ataque de ransomware, una falla eléctrica, un empleado descontento o un simple error humano pueden detener la operación. La gestión de riesgos permite pasar de *reaccionar ante incidentes* a *anticiparse* a ellos, invirtiendo recursos donde realmente se necesitan.

3. Conceptos Fundamentales

Para analizar riesgos, primero debemos tener clara la terminología. Estos conceptos, ya introducidos en clases anteriores, aquí toman su dimensión metodológica.

Activo Informático

Cualquier recurso, componente o elemento que tiene **valor** para la organización y que es necesario proteger para garantizar la operación del negocio.

Tipos de activos

- **Información:** bases de datos, propiedad intelectual, datos de clientes, planes estratégicos.
- **Software:** aplicaciones críticas, sistemas operativos, ERP.
- **Hardware (físicos):** servidores, notebooks, routers, UPS.
- **Redes y comunicaciones:** enlaces de internet, redes internas, servicios en la nube.
- **Humanos:** personal clave, administradores de sistemas.
- **Imagen corporativa y reputación.**

Amenaza

Causa potencial de un incidente no deseado que puede resultar en daño a un sistema u organización. Pueden ser:

- **Naturales:** inundaciones, terremotos, tormentas eléctricas.
- **Accidentales:** fallas de hardware, errores humanos, cortes de energía.
- **Intencionales:** ataques informáticos, sabotaje interno, espionaje industrial.

Vulnerabilidad

Debilidad intrínseca de un activo o de un grupo de activos que puede ser explotada por una o más amenazas.

Impacto

Consecuencia (pérdida o daño) que sufre un activo cuando una amenaza materializa su efecto explotando una vulnerabilidad. Puede medirse en términos **económicos, operativos, legales o reputacionales**.

Probabilidad

Medida de la posibilidad de que una amenaza concreta explote una vulnerabilidad en un período de tiempo determinado.

Riesgo

Combinación de la **probabilidad** de que un evento ocurra y sus **consecuencias** (impacto) sobre los activos de la organización.

$$\text{Riesgo} = \text{Probabilidad} \times \text{Impacto}$$

El triángulo del riesgo

El riesgo nace de la intersección de tres elementos:

1. **Amenaza** (el agente externo o evento).

2. **Vulnerabilidad** (la debilidad interna del activo).

3. **Activo** (lo que tiene valor y puede perderse).

Si eliminas o reduces uno de estos componentes, el riesgo disminuye.

4. El Proceso de Análisis de Riesgos

El análisis de riesgos puede abordarse desde dos enfoques metodológicos principales.

4.1. Análisis Cualitativo

Utiliza escalas subjetivas (por ejemplo: Bajo, Medio, Alto) para evaluar la probabilidad y el impacto. Se basa en la experiencia, el juicio de expertos y el consenso.

- **Ventajas:** rápido, fácil de comunicar, no requiere datos históricos precisos.
- **Desventajas:** subjetivo, difícil de usar para justificar presupuestos económicos.

Herramienta típica: Matriz de calor (heatmap) de Probabilidad vs. Impacto.

4.2. Análisis Cuantitativo

Asigna valores numéricos y monetarios a los componentes del riesgo. Permite calcular pérdidas esperadas y realizar análisis de retorno de inversión (ROI) en seguridad.

Las métricas clásicas son:

Métrica	Fórmula	Significado
SLE	Activo $\times$ Factor de Exposición	<i>Single Loss Expectancy</i> : Pérdida esperada por un único incidente.
ARO	Eventos por año	<i>Annual Rate of Occurrence</i> : Frecuencia anual estimada del evento.
ALE	$SLE \times ARO$	<i>Annual Loss Expectancy</i> : Pérdida monetaria anual esperada.

Análisis cuantitativo de un servidor web

- Valor del servidor (activo): USD 50.000
- Amenaza: ataque DDoS que lo deja fuera de línea
- Factor de exposición: 50 % del valor (por lucro cesante y costos de recuperación)
- $SLE = 50.000 \times 0,50 = \text{USD } 25.000$
- $ARO = 2$ veces por año (histórico)
- $ALE = 25.000 \times 2 = \text{USD } 50.000$ anuales de pérdida esperada

Si implementar una solución anti-DDoS cuesta USD 8.000 al año y reduce el ALE a USD 10.000, la decisión económica es clara: la salvaguarda **se justifica**.

5. Diseño de Salvaguardas

Una vez analizados los riesgos, la organización debe decidir cómo tratarlos. Las opciones clásicas son:

Opciones de tratamiento del riesgo

1. **Mitigar (implementar salvaguardas):** aplicar controles técnicos, físicos o administrativos para reducir la probabilidad o el impacto.
2. **Transferir:** pasar parte del riesgo a un tercero (por ejemplo, seguros de ciberseguridad, outsourcing).
3. **Aceptar:** asumir el riesgo porque su tratamiento sería más costoso que el impacto esperado.
4. **Evitar:** discontinuar la actividad que genera el riesgo (por ejemplo, dejar de operar un servicio de alto riesgo).

Salvaguarda (Contramedida o Control)

Medida que reduce el riesgo. Se clasifican según su naturaleza:

- **Técnicas (lógicas):** firewalls, cifrado, antivirus, IDS/IPS.
- **Físicas:** cerraduras, CCTV, UPS, control de acceso biométrico.
- **Administrativas:** políticas, procedimientos, capacitaciones, análisis de antecedentes.

6. Riesgo Residual

Riesgo Residual

Es el riesgo que **permanece** después de aplicar las salvaguardas y controles. Nunca se llega a riesgo cero; la organización debe **acceptar conscientemente** un nivel de riesgo residual alineado con su apetito de riesgo.

$$\text{Riesgo Residual} = \text{Riesgo Inicial} - \text{Reducción por Salvaguardas}$$

Punto crítico para el Trabajo Integrador

En el informe que elabores para la Actividad A03, para cada riesgo identificado debes mostrar:

1. El riesgo **inicial** (sin controles o con los controles actuales).
2. Las **salvaguardas** que proponés implementar.
3. El riesgo **residual** esperado después de aplicarlas.

Este es el corazón de un análisis profesional de riesgos.

7. La Matriz de Riesgos

La **matriz de riesgos** (o mapa de riesgos) es la herramienta gráfica que consolida todos los riesgos identificados y permite priorizarlos.

7.1. Estructura típica (enfoque cualitativo)

Probabilidad \ Impacto	Bajo	Medio	Alto
Alta	Medio	Alto	Crítico
Media	Bajo	Medio	Alto
Baja	Bajo	Bajo	Medio

- **Riesgos críticos y altos:** deben tratarse con prioridad inmediata.
- **Riesgos medios:** plan de acción a mediano plazo.
- **Riesgos bajos:** monitoreo continuo, pueden aceptarse.

Inventario de activos, paso previo

Antes de armar la matriz, se debe elaborar un **inventario de activos** donde se identifique cada activo, su responsable, su clasificación (público, interno, confidencial, restringido) y su valor para el negocio. De este inventario nacen los riesgos a analizar.

8. Glosario de conceptos clave

Activo	Recurso con valor para la organización.
Amenaza	Causa potencial de un incidente adverso.
Vulnerabilidad	Debilidad que puede ser explotada.
Probabilidad	Chance de ocurrencia de un evento.
Impacto	Consecuencia (económica, operativa, legal, reputacional).
Riesgo	Combinación de probabilidad e impacto.
Salvaguarda	Control que reduce el riesgo.
Riesgo Residual	Riesgo que permanece tras aplicar controles.
Apetito de riesgo	Nivel de riesgo que la organización está dispuesta a aceptar.
SLE	Pérdida esperada por un único incidente.
ARO	Frecuencia anual esperada del evento.
ALE	Pérdida anual esperada.
Matriz de Riesgos	Herramienta para visualizar y priorizar riesgos.

9. Autoevaluación

Respondé por escrito y sin apuntes; luego verificá tus respuestas en la Sección 10.

1. Explicá por qué se dice que «**el riesgo cero no existe**» y qué implicancia tiene esto en la toma de decisiones de una organización.
2. Identificá en el siguiente escenario los cinco componentes (Activo, Amenaza, Vulnerabilidad, Impacto, Probabilidad): «*Una empresa de logística tiene su base de datos de clientes en un servidor sin actualizar, accesible desde Internet. Históricamente, cada dos años sufre intentos de explotación de vulnerabilidades conocidas que pueden dejar el sistema fuera de servicio durante 3 días.*»
3. Calculá el **ALE** de la siguiente situación: un servidor de producción vale USD 100.000; si sufre un incendio, el factor de exposición es del 70 %; el incendio se estima que podría ocurrir una vez cada 10 años.
4. Diferenciá los tres tipos de **salvaguardas** (técnicas, físicas y administrativas) con un ejemplo para cada una aplicado al riesgo de robo de notebooks de los empleados.
5. ¿Qué es el **riesgo residual** y por qué su análisis es obligatorio en un informe profesional de ciberseguridad?

10. Respuestas de la Autoevaluación

Nota para el estudiante

Estas respuestas son **de referencia**. Se valora la claridad conceptual, el uso correcto de la terminología y la capacidad de vincular los conceptos con casos reales o del propio trabajo integrador.

Pregunta 1: Por qué el riesgo cero no existe

Respuesta

El riesgo cero no existe porque:

- Siempre aparecen nuevas vulnerabilidades (zero-days) y amenazas (nuevas técnicas de ataque, IA ofensiva, computación cuántica futura).
- Las salvaguardas nunca son 100 % efectivas (pueden estar mal configuradas, desactualizadas o eludirse).
- Existe siempre el factor humano (error, ingeniería social, amenazas internas).
- Eliminar *todo* el riesgo haría inviable operar el negocio (un sistema 100 % seguro es un sistema inutilizable).

Implicancia: las organizaciones definen un *apetito de riesgo* y aceptan un nivel de **riesgo residual** que sea asumible. La gestión de riesgos es, entonces, un proceso continuo de reducción y aceptación consciente, no de eliminación total.

Pregunta 2: Identificación de componentes**Respuesta**

- **Activo:** la base de datos de clientes alojada en el servidor de la empresa de logística.
- **Amenaza:** atacantes que intentan explotar vulnerabilidades conocidas desde Internet.
- **Vulnerabilidad:** el servidor sin actualizar (parches faltantes) y con exposición pública innecesaria.
- **Impacto:** caída del sistema durante 3 días (pérdida operativa, reputacional y económica).
- **Probabilidad:** alta — cada dos años ocurre un intento, es decir, $ARO \approx 0,5$.

Pregunta 3: Cálculo del ALE**Respuesta**

Paso a paso:

1. **SLE** (pérdida por un único incendio):
 $SLE = \text{Valor del activo} \times \text{Factor de exposición} = 100.000 \times 0,70 = \text{USD } 70.000$
2. **ARO** (frecuencia anual):
 $1 \text{ evento cada } 10 \text{ años} \Rightarrow ARO = 1/10 = 0,1$
3. **ALE** (pérdida anual esperada):
 $ALE = SLE \times ARO = 70.000 \times 0,1 = \text{USD } 7.000 \text{ por año}$

Esto significa que, estadísticamente, la empresa debería presupuestar USD 7.000 anuales para cubrir el riesgo de incendio. Cualquier salvaguarda (sistema contra incendios, data center redundante, etc.) que cueste menos que ese valor y reduzca el riesgo, se justifica económicamente.

Pregunta 4: Tipos de salvaguardas aplicadas al robo de notebooks**Respuesta**

- **Salvaguarda técnica:** cifrado de disco completo con BitLocker o FileVault, de modo que aun si roban el equipo, la información sea inaccesible sin la clave.
- **Salvaguarda física:** candados Kensington, salas de almacenamiento con acceso restringido, cámaras de seguridad en oficinas.
- **Salvaguarda administrativa:** política de uso aceptable, capacitación a empleados sobre custodia de equipos, procedimiento de reporte inmediato de robo y borrado remoto mediante MDM.

La estrategia más robusta combina las tres (Defensa en Profundidad).

Pregunta 5: Riesgo residual y su importancia

Respuesta

El **riesgo residual** es el nivel de riesgo que **permanece después de aplicar las salvaguardas**. Nunca es cero.

Su análisis es obligatorio en un informe profesional porque:

- Demuestra que el profesional **evaluó la efectividad real** de los controles propuestos.
- Permite a la dirección decidir si ese nivel residual es **aceptable** o si se requieren controles adicionales.
- Documenta el **apetito de riesgo** de la organización, clave para auditorías y para ISO 27001.
- Evita la falsa sensación de «seguridad total» al dejar explícito que aún quedan riesgos asumidos.

En la fórmula: $\text{Riesgo Residual} = \text{Riesgo Inicial} - \text{Efecto de Salvaguardas}$.

11. Recordatorio: Actividad A03

Consigna A03 — Administración de Riesgos

Diseñar y elaborar un **análisis de riesgo** para una empresa real, ficticia o el caso elegido en el Trabajo Integrador.

El informe debe incluir:

1. Inventario y clasificación de activos.
2. Identificación de amenazas y vulnerabilidades.
3. Análisis (cualitativo con matriz de calor, o cuantitativo con SLE/ARO/ALE).
4. Diseño de salvaguardas propuestas.
5. Cálculo del riesgo residual.

Subilo a la carpeta del Trabajo Integrador en Google Drive, otorgando permisos de comentario a era.profe@gmail.com.

Rúbrica de evaluación (según grilla de la cátedra):

Criterio	Peso	Qué se espera para el «Excelente»
A. Recopilación de información	30 %	Utiliza de manera completa fuentes confiables y las cita correctamente.
B. Elaboración de documentos	30 %	Cumple adecuadamente con los formatos atento a la planilla de estandarización brindada por la cátedra.
C. Elaboración de presentaciones	10 %	Argumenta de manera sólida el inconveniente del caso y su solución.
F. Consciencia de buenas prácticas	30 %	Evidencia permanentemente el uso de buenas prácticas en el análisis.

12. Fuentes y bibliografía

12.1. Bibliografía obligatoria (según programa)

- Chicano Tejada, E. (2023). *Auditoría de seguridad informática. IFCT0109* (2.^a ed.). IC Editorial — eLibro.
- Elgueta, R. (s.f.). *Guías de Clase unidad I*. Material inédito. UCH.

12.2. Bibliografía complementaria (según programa)

- Bancal, D. (2022). *Seguridad informática* (5.^a ed.). Ediciones ENI.
- Evans, L. (2019). *Ethical Hacking: The Ultimate Guide to Using Penetration Testing to Audit and Improve the Cybersecurity of Computer Networks for Beginners, Including Tips on Social Engineering*. Amazon Digital Services LLC — KDP.
- White, A. & Clark, B. (2017). *BTFM: Blue Team Field Manual*. CreateSpace Independent Publishing Platform.
- ISO/IEC (2005). *Information security management 27001*.
- ISO/IEC (2018). *ISO/IEC 27005: Information security risk management*.
- NIST (2012). *Guide for Conducting Risk Assessments (SP 800-30 Rev. 1)*.
- Lardent, A. R. (2001). *Sistemas de información para la gestión empresarial: procedimientos, seguridad y auditoría*. Pearson Publications.

12.3. Portales y recursos web

- Portales CERT, NIST, Hispasec y otros relacionados.
- Plantilla de Matriz de Riesgos de la cátedra (campus virtual).
- OWASP Risk Rating Methodology: https://owasp.org/www-community/OWASP_Risk_Rating_Methodology